Privacy Impact Assessment (PIA) - Employee Health App

1. Project Description

The Employee Health App is designed to track employee health metrics, including daily steps, heart rate, and sleep patterns. The collected data will be stored on a company server located in the US.

2. Data Collected & Data Flow

The app collects **Sensitive Personal Data** (health metrics) and personal identifiers. The data flows from the employee's mobile device directly to the company's data center in the US.

3. Privacy Risks

Risk 1 (Data Residency Violation): Storing UAE employee data in the US violates UAE PDPL data localization requirements.
Risk 2 (Data Breach): Sensitive health data is at risk of interception or breach during transmission to the US server.

4. Mitigation Controls

Control 1 (Data Localization): Migrate the data storage to a UAE-based server to comply with PDPL.
Control 2 (Security): Implement end-to-end encryption for data in transit and enforce MFA for all users accessing the app.